

NYC / AI AGENT SECURITY SUMMIT

Your Agent Escaped Without Escaping the Sandbox

Yossi Eliaz

Principal Engineer and Head of DevRel at Incredibuild.com

October 21, 2026

What makes it eligible for release?

**The VM held.
The green check did not.**

Dev produces. Controller freezes. Accept VM executes frozen bytes.

Controller compares. Gate publishes those bytes, or nothing.

Recorded Linux isolation run + factory

We protected the checker. The worker still decided.

checker.py	hash unchanged
expected.json	worker-written
task check	PASS

independent case "1,,3"	REJECT required
buggy parser	[1, 3]

The checker imported its truth from the workspace.

Recorded Linux isolation run + factory

Verified bytes are not released bytes

Publish from the live path after a swap Wrong artifact

Hash the path, then hash it again Not a freeze

Evaluate and publish the frozen object Same digest

Approval reused or applied to other bytes Denied

Collect, store, digest, evaluate that object, publish that object.

Recorded Linux isolation run + factory

Three other grants. Same pattern.

identity	broad token reads another project; task token 403
files	writable bind changes the next job; read-only holds
release	allowed upload, wrong account; broker fixes both

Independent synthetic checks. Not one exploit chain.

Recorded Linux isolation run + factory

Where judgment lives

Piece

Candidate execution

Expected results and compare

Harness PASS / reports / URLs

Timeout or malformed output

Publication

Recorded Linux isolation run + factory

Owner

Fresh accept VM, frozen bytes only

Controller

Log only, never approval

No approval

Frozen object after a valid accept

The job, with judgment moved

1. Worker writes a candidate. Controller freezes it.
2. Accept VM runs those bytes. Controller compares.
3. Gate accepts the good digest. Swap and replay die.
4. Worker reports and expected.json do not ship the bug.

1,,3 returns REJECT. The permitted report goes out.

Recorded Linux isolation run + factory

Four boundaries to check

Question

Whose identity?

Which files, including the next job?

Which recipient and contents?

Who can approve these bytes?

Then confirm the legitimate operation still works.

Must refuse outside the worker

Service grant

Host and snapshot policy

Broker and network policy

Controller compare and gate

THE QUESTION TO TAKE HOME

Who gave this process the authority?

github.com/zozo123/nyc-talk

Yossi Eliaz

Appendix / Reproduction

```
make factory      # controller freeze, judge, gate
make demo         # educational Linux isolation lab
make deck         # evidence check + PDF
python3 tools/present.py credentials
```

29 lab checks passed, 6 factory checks passed.

Appendix / Limits

Reference factory plus synthetic lab. Deterministic scripts.

Five cases prove five cases, not parser correctness.

No named-product zero-day, customer incident, or model success-rate.

Timeouts and crashes are no approval, not a successful defense.

Appendix / Primary references

pytest plugins

Loading worker-influenced plugins is documented behavior

Anthropic reward hacking

Process-exit graders are known; not our novelty claim

SLSA verifying artifacts

Authenticity is not artifact identity